Memori CTI

THREAT ADVISORY · MACOS

macOS ClickFix strikes again

A fake CAPTCHA quietly mounts a hidden disk image — then hands an AMOS infostealer the keys to your crypto wallets.

Research by **Unit 42**

THE THREAT AT A GLANCE

A click that costs your wallet

> A new **ClickFix** campaign tricks victims into pasting one command into **Terminal**. It silently downloads and mounts a malicious DMG — no Finder window, no progress bar.
>
> Inside is a self-signed infostealer from the **AMOS (Atomic macOS Stealer)** family — the modern C++ **"Odyssey"** variant.

PLATFORM **macOS (Intel + ARM64)**	MALWARE FAMILY **AMOS · Odyssey variant**
PRIMARY GOAL **Crypto & credential theft**	INITIAL VECTOR **Fake CAPTCHA → Terminal**

KNOW THE TRICK

What is “ClickFix”?

> ClickFix is social engineering that turns the victim into the installer. Instead of exploiting software, it exploits **trust and habit**.
>
> A page poses as a “human verification” step and asks you to **open Terminal and paste a command** to “prove you’re not a robot.” The instructions usually walk you through Spotlight (⌘ + Space) → Terminal → paste → Enter.
>
> There is no verification. The pasted text **is** the attack.

HOW THE ATTACK UNFOLDS

The infection chain

1. **Fake CAPTCHA** page instructs the user to copy a “verification” command.
2. Command is **pasted into Terminal**, spawning a hidden Bash shell.
3. **curl** silently downloads a malicious **.dmg** into a temp file.
4. **hdiutil** mounts the image **invisibly** — bypassing Finder and the Desktop.
5. A search finds the bundled **.app** and macOS **open**'s it instantly.
6. The **infostealer** launches and begins harvesting — all from one paste.

BEHIND THE COMMAND

The silent one-liner

> The pasted command looks harmless but chains several steps to stay **completely invisible**:

- **Silent download:** `curl -fsSL` fetches the payload with no progress bar and no errors shown.
- **Invisible mount:** `hdiutil attach -nobrowse` mounts the DMG without ever opening Finder.
- **Auto-locate:** `find` digs up to 3 folders deep for the first `.app` / `.pkg`.
- **Auto-launch:** the native `open` command runs the malware — no double-click needed.

THE PAYLOAD — NNAPP.APP

What it steals

BROWSERS

8 Chromium browsers (Chrome, Edge, Brave, Arc, Opera, Vivaldi, Yandex, CocCoc) and **5 Firefox**-based (Tor, LibreWolf, Waterfox, Zen, SeaMonkey) — cookies, logins, autofill.

CRYPTO WALLETS

13 desktop wallets — Exodus, Electrum, Atomic, Wasabi, Bitcoin/Litecoin Core, Guarda, Binance, TonKeeper & more, plus wallet browser extensions.

MESSAGING

Telegram Desktop and **Discord** (including its Keychain Safe Storage key).

SYSTEM & FILES

Apple **Notes**, Safari cookies, the macOS **login Keychain**, and documents (.pdf / .txt / .rtf).

THE CRYPTO ANGLE

It hijacks your hardware wallet apps

> Beyond stealing files, the malware performs a **supply-chain style swap**: it downloads trojanized bundles from its C2 and replaces the genuine apps in `/Applications`.
>
> **Ledger Live** and **Trezor Suite** are overwritten with malicious look-alikes — so even “cold” hardware-wallet users can be funneled toward attacker-controlled flows.
>
> It also asks for your password through a fake **System Preferences** dialog and validates it against the system before continuing.

STAYING & SENDING

Persistence & exfiltration

- **Staging:** creates a hidden folder `~/.hlpr/` and drops victim & system info.
- **Persistence:** installs a LaunchAgent at `~/Library/LaunchAgents/com.hlpr.agent.plist`.
- **Packaging:** zips everything with `ditto` for upload.
- **Exfiltration:** POSTs the archive to a C2 endpoint (`/api/reports/upload`).

> Strings and config are **XOR-encrypted** and decrypted only in memory — making static detection harder.

PROTECT YOURSELF

How to stay safe

- ✓ **Never paste a command from a website into Terminal.** No legitimate CAPTCHA needs that.
- ✓ Be suspicious of any “verification” that mentions **Spotlight or Terminal**.
- ✓ Install wallet apps only from **official sources**; verify signatures.
- ✓ Check for `~/.hlpr/` and unknown **LaunchAgents**; rotate seed phrases & passwords if hit.
- ✓ Block the listed C2 indicators and keep **EDR / XProtect** current.

Indicators of compromise

Domains svs-verificationdate[.]beer
fewfwfwfwfwf[.]info

IPs 178.16.52[.]101 · 196.251.107[.]171

Host ~/.hlpr/ · com.hlpr.agent.plist
/Volumes/NNApp/NNApp.app · com.utils.nnapp

Full technical analysis & hashes by **Unit 42** — M. Satpathy, B. Rathod, S. Khaja & V. Senderovych.
Stay vigilant. **Follow Memento Mori for more threat intel.**